Login seguro, accesible y controlado por teclado

Matías Lira Breyan Sebastián

—

Desarrollo Web Profesional

—

José Miguel Carrera Pacheco

¿CÓMO DEBE COMPORTARSE UN FORMULARIO ACCESIBLE?

Un formulario accesible es aquel que puede ser utilizado correctamente por todas las personas, incluyendo usuarios con discapacidades visuales, motoras o cognitivas.

Las buenas prácticas de accesibilidad son promovidas por el World Wide Web Consortium mediante las guías de accesibilidad web.

Características de un formulario accesible

Etiquetas claras (labels)

Cada campo debe tener una etiqueta que describa su función.

Ejemplo:

```
<label for="correo">Correo electrónico</label>
<input type="email" id="correo" name="correo">
```

Esto permite que los lectores de pantalla identifiquen correctamente los campos.

Instrucciones visibles

Si un campo requiere un formato específico, el usuario debe saberlo antes de escribir.

Ejemplo:

La contraseña debe tener al menos 8 caracteres.

Navegación con teclado

Todos los campos del formulario deben poder utilizarse con la tecla **Tab**, permitiendo avanzar entre ellos sin usar el mouse.

Mensajes de error claros

Cuando ocurre un error, el sistema debe:

- indicar qué campo tiene el problema
- explicar cómo corregirlo

Agrupación de campos relacionados

Los campos relacionados deben organizarse de forma lógica para facilitar la comprensión del formulario.

ERRORES COMUNES EN FORMULARIOS DE LOGIN

Los formularios de inicio de sesión son una de las partes más críticas de una aplicación web.

Sin embargo, es común encontrar errores de diseño que afectan la experiencia del usuario y la seguridad.

Pedir demasiada información

Un formulario de login debería solicitar solo lo necesario, normalmente:

- usuario o correo electrónico
- contraseña

Solicitar información adicional puede generar fricción.

Mensajes de error confusos

Mensajes poco claros pueden frustrar al usuario.

Ejemplo incorrecto:
Error de autenticación.

Ejemplo mejor:
El correo o la contraseña son incorrectos.

Falta de opción para recuperar contraseña

Un buen sistema de login debe ofrecer una opción de recuperación de contraseña.

Falta de indicadores de seguridad

Los usuarios deben saber que el sitio es seguro.

Por ejemplo:

- uso de HTTPS
- mensajes de seguridad
- autenticación en dos factores

Problemas en dispositivos móviles

Algunos formularios no están optimizados para pantallas pequeñas o teclados móviles.

¿CÓMO SE MANEJAN SESIONES DE FORMA SEGURA?

Las sesiones permiten mantener a un usuario autenticado mientras navega dentro de una aplicación.

Si no se gestionan correctamente, pueden convertirse en un riesgo de seguridad.

Uso de cookies seguras

Las cookies de sesión deben configurarse con atributos de seguridad como:

- Secure
- HttpOnly
- SameSite

Esto ayuda a evitar que scripts maliciosos accedan a la sesión.

Expiración de sesiones

Las sesiones deben tener un tiempo de expiración para evitar accesos prolongados no autorizados.

Por ejemplo:

- cerrar sesión automáticamente después de cierto tiempo de inactividad.

Regeneración de ID de sesión

Cuando un usuario inicia sesión, el sistema debería generar un nuevo identificador de sesión para evitar ataques de secuestro de sesión.

Cerrar sesión correctamente

Al cerrar sesión, el sistema debe:

- destruir la sesión en el servidor
- eliminar las cookies relacionadas

¿CÓMO SE MUESTRAN ERRORES DE AUTENTICACIÓN SIN FILTRAR INFORMACIÓN SENSIBLE?

Cuando ocurre un error en el proceso de autenticación, el sistema debe informar al usuario sin revelar información que pueda ser utilizada por atacantes.

Evitar revelar información específica

Un error común es mostrar mensajes como:
El usuario no existe.

Esto permite a un atacante saber qué cuentas son válidas.

En su lugar se recomienda usar mensajes como:
El usuario o la contraseña son incorrectos.

No mostrar detalles técnicos

Los mensajes de error no deben incluir:

- nombres de bases de datos
- rutas del servidor
- errores internos del sistema

Registrar errores internamente

La información técnica debe registrarse en logs del sistema, no mostrarse al usuario.

Esto permite que los desarrolladores puedan analizar el problema sin comprometer la seguridad.

Limitar intentos de acceso

Si ocurren demasiados intentos fallidos, el sistema puede:

- bloquear temporalmente la cuenta
- solicitar verificación adicional